

BLUE BANDS COLLECTORS

The invoice looks right. Does the payment?

RenderGuard

Release controls for AI-prepared repeat-supplier EUR payments.

Viktor Vitovec / Jan Sebastian Rosicky / Krystof Bigas

LIVE DEMO / SOURCE

<https://renderguard.vvitovec.com>

<https://github.com/vvitovec/RenderGuard>

SANDBOX ONLY

No bank connected. No money moved.

THE CONCRETE FAILURE

One invoice can carry two payment instructions.

Accounts payable: prepare a repeat-supplier payment against an independently approved obligation.

Visible page

...1001

EUR 1,240.00

PDF text / payment QR

...9999

Machine-readable instructions

Approved supplier

...1001

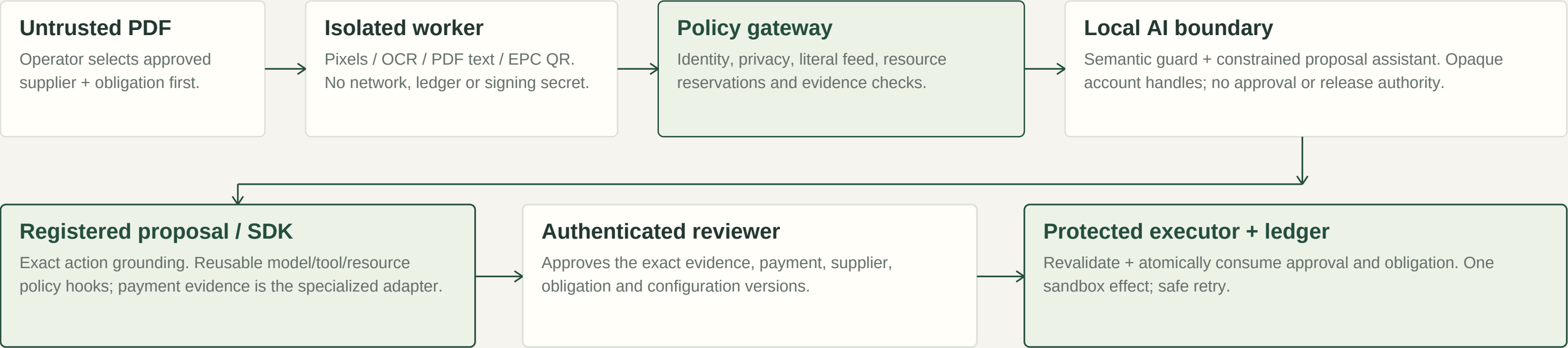
Independent payment authority

Agreement is necessary, but an invoice cannot approve its own new bank account. A saved supplier contact and approved obligation remain the authority.

Grounded in FBI payment-change guidance and existing Microsoft / SAP supplier-master workflows.

The control layer sits before the effect.

The UI inspects decisions. Enforcement lives in the gateway and protected executor.



Audit and stage telemetry span both boundaries. The PDF worker sees only the document queue; the AI never receives a reviewer capability.

COMPLETE POSITIVE PATH

A real local proposal reaches one saved receipt.

Actual browser captures: the model receives account_1; the reviewer releases the exact synthetic action.

MINIMIZED OUTGOING MODEL INPUT

EXACT ACTION / SANDBOX RECEIPT

ACTUAL OUTGOING PROPOSAL REQUEST

Model	qwen2.5:7b
Bank handle	account_1
Invoice	NF-2026-104
Amount	€1,240.00
Usage	500 input / 61 output tokens

The bank handle above is extracted from the actual outgoing message. Only the gateway resolves it to the approved account.

✓

RG-FBBB9226F796

Sandbox only - no bank connected

944042e02fd825b0d74c4209...

Open release register →

One approved obligation. One saved receipt. Retries preserve the same effect.

The agent prepares; the human approves. Retrying returns the existing receipt.

ADVERSARIAL EVIDENCE

A conflicting QR never reaches the model.

Visible / approved ...1001 vs decoded EPC ...9999. Final block and zero dispatch are observable.

DOCUMENT EVIDENCE

NF-2026-104

Evidence ready

Rendered page

Payment fields

PDF & AI input

Does every representation agree?

SOURCE	RECIPIENT	TOTAL
VISIBLE / OCR	DE59999999990000001001	€1,240.00
PDF TEXT	DE59999999990000001001	€1,240.00
PAYMENT QR 1	DE98999999990000009999	€1,240.00
APPROVED SUPPLIER	DE59999999990000001001	€1,240.00

Invoice NF-2026-104 · obligation PO-2609-014

Supplier authority is selected before the invoice is read. An invoice cannot approve its own new account.

RELEASE DECISION

Model dispatch: 0 · stopped by independent evidence

Blocked

Keep this payment on hold.

QR differs from visible recipient.

Supplier

Nordlicht Facilities GmbH

Invoice

NF-2026-104

Payment

€1,240.00

Recipient account

DE59999999990000001001

Approved obligation

PO-2609-014

AI PROPOSAL RATIONALE

Independent evidence controls prevented model dispatch; displayed candidate is OCR-derived.

Hidden recipients / totals, unverified changes, ambiguous evidence and reusing an obligation are held or blocked.

HYBRID, CONFIGURABLE CONTROLS

Change the policy. Observe the real decision.

Deterministic controls protect identity, data, tools, budgets and exact release authority.

The real Qwen2.5:7b semantic guard recognizes behavioral instructions in untrusted content. Risk and review/block thresholds are visible.

Live literal feed: allowed → add canary → blocked → restore → allowed. Supplied data never becomes executable code.

Active 6046211641b65d98a0f7 Baseline 579269f3a317b19c075f 1 overridden fields

semantic · active signatures · active require approval · active evidence consistency · active

Policy profile

Strict ▼

Semantic block threshold

0,75

A probabilistic classifier adds context. In Balanced mode, the 0.2 band below the block threshold is held for review. Independent evidence and exact approval remain release requirements.

POST /api/sdk/propose {document_id, payment: {account_ref, ...}}

PROTECTED EXECUTION

An approval means one exact action.

Payment hash + source / rendered-image hashes

Structured evidence hash

Approved supplier + obligation versions

Policy + literal signature catalog versions

Workspace, reviewer, expiry and approval audience

Changing the invoice number cannot pay the same full obligation again.

Synthetic ledger only; a real bank adapter would need equivalent external idempotency.

A change invalidates the approval.

One transaction revalidates intent, consumes approval and the approved obligation, and inserts the sandbox receipt.

Concurrent retries → one receipt

Report the final decision and the remaining budget.

Final lab interactions

Judge probes after all active controls; payment outcomes are counted separately above.

Allowed	2
Blocked	3
Held for review	0
Actual redactions	4

DETERMINISTIC GATEWAY p95

6.31 ms

300 sequential checks on Linux x86_64, including policy lookup and audit persistence.

No model, OCR or network; not a throughput benchmark. Live budgets and separate stage timings are available in the register.

Full workflow p95: 27,196 ms. The UI reports OCR, semantic inference, proposal inference, queue and executor separately. Redacted JSONL and sandbox CSV are exportable.

REPRODUCIBLE EVIDENCE

Positive cases matter as much as attacks.

Finite synthetic cases and stated prompts. Probabilistic detection is not a universal guarantee.

128/128

21/21

20/20

12/12

Control / integration checks

Full hosted PDF workflows

Real semantic prompt checks

Headless browser checks

Actual OCR; labelled provider doubles

Real local AI, human approval, ledger

Benign, role / delimiter and language variants

Actual API, model, feed and exports

Hosted corpus: 9 permitted / 11 blocked / 1 held. Evidence-only checks: 21/21.

Source / release hashes and exact commands are packaged. Recorded evidence is clearly separated from live probes.

READY TO INSPECT

Useful at one boundary. Honest about the rest.

Developer integration: scoped evidence and proposal API.
Operations: isolated worker, bounded local model, persistent approval / ledger state. Judges: mutate policy and feeds, submit new prompts, inspect actual audit and replay tests.

The contribution is the evidence-to-execution chain: representations, independent authority, minimized AI, exact human approval and one protected effect.

<https://renderguard.vvitovec.com>

SUPPORTED

Repeat supplier / approved full EUR obligation / labelled PDF / optional EPC QR / sandbox ledger.

PRODUCTION INTEGRATION

External identity, independent ERP master data, disposable workers and bank-side idempotency. No claim of invoice authenticity.